

Vulnerability Assessment Report

DownUnderNewsz - Penetration Test Report

DownUnderNewsz

22 Arthur St
Fairfield VIC 3078, Australia

September 18, 2026

Report Version: 1.0

Flinders University
Sturt Road, Bedford Park SA
5042

Table of Contents

List of Figures	4
1 Document Control	5
1.1 Team	5
1.2 List of Changes	5
2 Executive Summary	6
2.1 Overview	6
2.2 Identified Vulnerabilities	7
3 Methodology	9
3.1 Objective	9
3.2 Scope	9
3.3 User Accounts and Permissions	10
4 Findings	11
C1: Server-Side Template Injection (SSTI) in Search — potential Remote Code Execution	11
M1: Anonymous FTP Read Access on Media Server Exposes Uploaded Files .	13
M2: Session Cookie Missing Secure and SameSite Attributes	14
M3: Missing Cross-Site Request Forgery (CSRF) Protection on Admin Actions	15
I1: Email Spoofing Enabled by Missing DMARC/DKIM and Softfail SPF	16
I2: Unicorn Application Port Directly Exposed to the Internet	17
I3: Malformed Editor Account Email Address	18
I4: Media Subdomain Backend Returns 502 Bad Gateway	19
I5: Missing HTTP Security Headers (HSTS, CSP, X-Frame-Options, X-Content-Type-Options)	20
I6: TLS Certificate SAN Mismatch on www Subdomain	21
I7: Unauthenticated API Discloses Author PII and Internal Identifiers	22
5 Disclaimer	23

A	Appendix	24
A.1	Static Appendix Section	24
A.2	Limitations & Constraints	24
A.3	Severity Classification	24

List of Figures

Figure 1 - Distribution of identified vulnerabilities	8
---	---

1 Document Control

1.1 Team

Contact	Details	Role
ClawSec	Autonomous agent	Pentester

1.2 List of Changes

Version	Description	Date
1.0	Initial report release	Sep 18, 2026

2 Executive Summary

2.1 Overview

Overview

DownUnderNewsz (trading as "The Down Under News") engaged ClawSec to perform an authorized, full-scope (black-box) vulnerability assessment of its public-facing web assets. Testing took place from 17 to 18 September 2026 and was limited to non-destructive techniques.

The assessment identified **11 findings**: 1 critical, 3 medium, 4 low, and 3 informational. The most serious issue is a server-side template injection (SSTI) vulnerability in the public search feature of the news website. This flaw allows an anonymous attacker to make the web server evaluate code supplied in the search box, which on this type of application can be escalated to full remote control of the web server.

What this means for the business

The critical vulnerability in the search feature is the top priority to fix. In plain terms, a remote attacker could potentially take over the news website, read or alter all published content, and access sensitive application configuration and secrets. This should be remediated immediately.

A number of supporting issues further weaken the overall security posture: the site does not enforce secure transport (HTTPS) for administrator sessions, its email domain can be impersonated by attackers, and its media server exposes uploaded files to anonymous visitors over FTP.

Findings summary

Severity	Count
Critical	1
High	0
Medium	3
Low	4
Informational	3

Top recommendations

1. Fix the search feature so that user input is never evaluated as server-side code (immediate priority).
2. Enable HTTPS enforcement (HSTS) and mark the administrator session cookie as `Secure` and `SameSite`.
3. Disable anonymous FTP access on the media server and restrict it to the application network.

4. Correct the TLS certificate so `www` is covered, and strengthen email authentication (SPF/DMARC/DKIM).
5. Remove direct internet exposure of the application port (5000) and bind it to localhost.

A detailed technical description and remediation guidance for each finding is provided in the body of this report.

2.2 Identified Vulnerabilities

#	CVSS	Description	Page
C1	9.8	Server-Side Template Injection (SSTI) in Search — potential Remote Code Execution	11
M1	5.3	Anonymous FTP Read Access on Media Server Exposes Uploaded Files	13
M2	5.3	Session Cookie Missing Secure and SameSite Attributes	14
M3	4.3	Missing Cross-Site Request Forgery (CSRF) Protection on Admin Actions	15
I1	0.0	Email Spoofing Enabled by Missing DMARC/DKIM and Softfail SPF	16
I2	0.0	Gunicorn Application Port Directly Exposed to the Internet	17
I3	0.0	Malformed Editor Account Email Address	18
I4	0.0	Media Subdomain Backend Returns 502 Bad Gateway	19
I5	0.0	Missing HTTP Security Headers (HSTS, CSP, X-Frame-Options, X-Content-Type-Options)	20
I6	0.0	TLS Certificate SAN Mismatch on www Subdomain	21
I7	0.0	Unauthenticated API Discloses Author PII and Internal Identifiers	22

Vulnerability Overview

In the course of this penetration test **1 Critical**, **3 Medium** and **7 Info** vulnerabilities were identified:

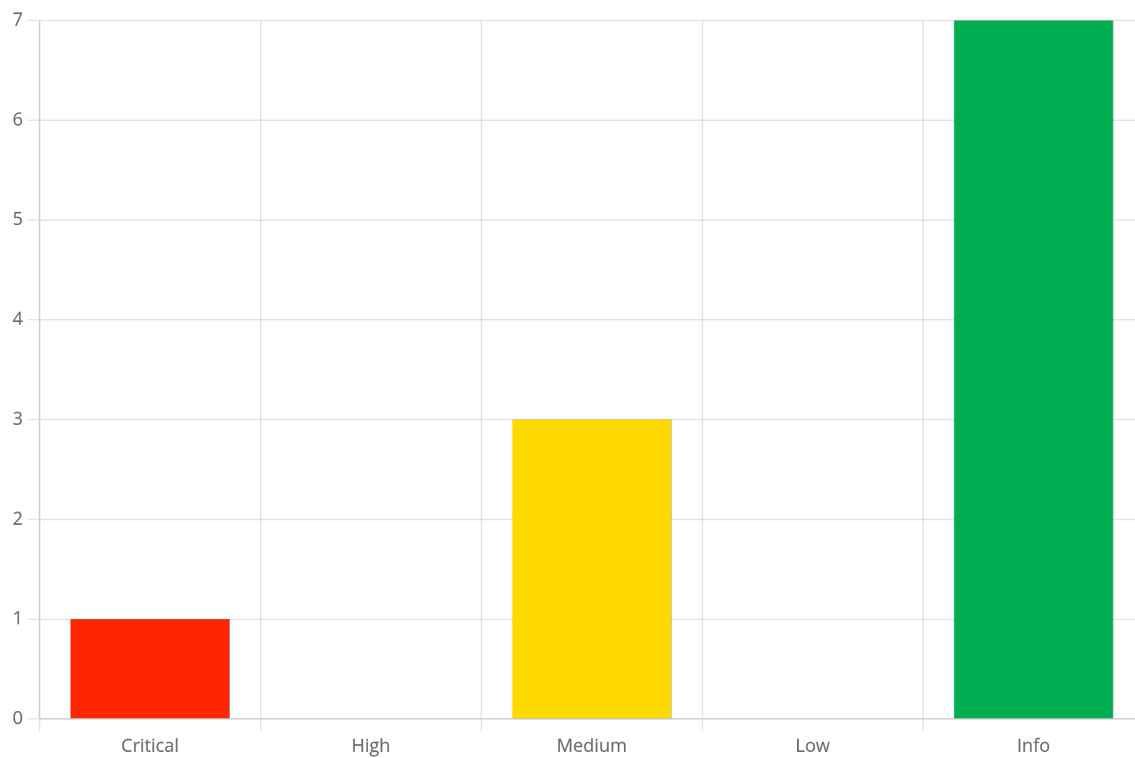


Figure 1 - Distribution of identified vulnerabilities

3 Methodology

This entire vulnerability assessment process was completed using agentic AI and existing LLM models. The purpose of such assessments is to automatically

3.1 Objective

The entire objective of this research is to evaluate the effectiveness of autonomously evaluate security posture for any business available on Google Map without the needs of technical guidance to determine how feasible, seamless and cost-affective such approach is.

3.2 Scope

In-scope assets

Asset	Type	IP / Technology
thedownundernews.online	Main news website	51.161.130.70 - Flask/Jinja2 behind nginx + Unicorn
www.thedownundernews.online	Main website alias	51.161.130.70
media.thedownundernews.online	Media server	51.161.131.195 - nginx + vsftpd + OpenSSH

Out of scope / excluded

The following were explicitly excluded from testing: OVH hosting infrastructure (AS16276), Spaceship Inc (registrar/DNS/email), jsDelivr, Google Fonts, the unregistered candidate domain `thedownundernews.it.com`, and all other third-party and network devices.

Engagement type

Authorized, full-scope (black-box) vulnerability assessment of public-facing web assets. Authorization was verified via a signed authorization header returned by the main website.

Methodology

Passive and active reconnaissance (DNS/WHOIS, certificate transparency, Shodan), fast full-port TCP discovery, service and version detection, web application testing (authentication/authorization, IDOR/ access control, injection including SSTI/XSS/SQLi, API review, session/cookie/CSRF, security headers, TLS), JWT configuration testing (`alg=none` and a bounded common-secret check), and FTP review. All testing was non-destructive.

3.3 User Accounts and Permissions

The owner provided three test accounts (admin, editor, writer) for authorized authenticated testing of the admin panel and API.

4 Findings

C1: Server-Side Template Injection (SSTI) in Search — potential Remote Code Execution	
Score	9.8 (Critical)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Target	• https://thedownundernews.online/search?q= • http://51.161.130.70:5000/
References	• OWASP Server Side Template Injection • CWE-94 • CWE-1336

Overview

Severity: Critical

The public search feature evaluates user-supplied input as a Jinja2 template expression on the server. This lets an anonymous attacker execute arbitrary template expressions and, on a typical Flask/Jinja2 deployment, chain them into full remote code execution on the web server.

Details

Submitting the query `{{7*7}}` to `/search?q=` caused the expression to be evaluated server-side and rendered as `49` in four separate locations of the response (the `<title>`, the results heading, the search input value, and the "No results" message). This is direct proof of server-side template evaluation rather than simple text reflection.

Because the site is a Flask application (Jinja2 templating served via Gunicorn), template injection of this kind is commonly escalated to arbitrary code execution using object introspection chains (e.g. `{{ config }}`, `{{ '.__class__.__mro__... }}`). Even in the absence of a proven shell, the ability to evaluate arbitrary server-side expressions is itself a critical defect.

Business impact: a remote attacker could gain full control of the web application and underlying host, read or alter all news content, and expose the application's configuration/secrets.

Recommendation

Never pass user-controlled data into a template engine for evaluation. Treat the search term strictly as data (render it through a Jinja variable with auto-escaping, e.g. `{{ query }}`), and do not use `render_template_string` on untrusted input. Add a code-level guard and regression test that `{{...}}`/

`{%...%}` input is never evaluated. Consider enabling a Jinja2 sandbox only as a stop-gap, and audit all other reflection points (article/category routes) for the same flaw.

M1: Anonymous FTP Read Access on Media Server Exposes Uploaded Files

Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Target	51.161.131.195:21 (media.thedownundernews.online) — vsftpd 3.0.5
References	• CWE-284 (Improper Access Control) • CWE-552 (Files/Directories Accessible to External Parties)

Overview

Severity: Medium

The FTP service on the media VPS permits anonymous login and directory listing, exposing the organization's uploaded media files (two PNG images and one PDF) to anyone on the internet without authentication.

Details

An anonymous FTP session to `ftp://51.161.131.195/` succeeded and returned a listing of `58e75939c3d24841806d3a069e919576.png`, `66ea642847be4ef0a800fb8cb8432d79.png`, and `d2273a1a2576489fb419cc1049c4c62f.pdf`. Write/upload was correctly denied (FTP 553), so the exposure is read-only, but the files may include confidential business documents. The filenames are hashed, which provides obscurity but not access control.

Recommendation

Disable anonymous FTP access (`vsftpd anonymous_enable=NO`), require authenticated access with strong credentials over FTPS/SFTP, and restrict access to the FTP port to the application server (e.g. via firewall or OVH security groups) so it is not internet-exposed.

M2: Session Cookie Missing Secure and SameSite Attributes	
Score	5.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:N/A:N
Target	https://thedownundernews.online/ (admin login session)
References	• OWASP Session Management Cheat Sheet • CWE-614 (Sensitive Cookie Without Secure) • CWE-1275

Overview

Severity: Medium

The admin session cookie (`access_token_cookie`, a JWT) is issued with `HttpOnly` but without the `Secure` or `SameSite` attributes. Combined with the missing HSTS header, this exposes authenticated admin sessions to hijacking.

Details

During authorized login tests, the server returned `Set-Cookie: access_token_cookie=...; HttpOnly; Path=/. The Secure flag is absent, so the cookie would be transmitted over plaintext HTTP if the client ever requests the site insecurely; because HSTS is also absent, an on-path attacker can perform SSL stripping to obtain the token. The missing SameSite attribute also removes an important built-in defense against cross-site request forgery.`

Recommendation

Set `Secure` and `SameSite=Lax` (or `Strict`) on the `access_token_cookie`. Enable HSTS so the browser always uses HTTPS. Review any refresh-token cookies for the same flags.

M3: Missing Cross-Site Request Forgery (CSRF) Protection on Admin Actions

Score	4.3 (Medium)
Vector string	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N
Target	• https://thedownundernews.online/admin/login • https://thedownundernews.online/admin/articles/new
References	• OWASP CSRF Prevention Cheat Sheet • CWE-352

Overview

Severity: Low

The admin login form and the article create/edit forms contain no CSRF token, and the session cookie carries no SameSite attribute, weakening protection against cross-site request forgery.

Details

The `/admin/login` form (POST `/admin/login`) and the article form (submitted to `/api/admin/articles`) contain no hidden CSRF token and no XSRF header. The session cookie lacks `SameSite`. In practice the JSON-based article API and the browser's default `SameSite=Lax` behavior partially mitigate CSRF, but the login endpoint and the multipart media upload (`/api/admin/media/upload`) remain simple cross-site requests that would carry the session cookie. An attacker could, for example, force a victim's browser to log them into an attacker-controlled account (login CSRF) or submit a media upload.

Recommendation

Implement CSRF tokens on all state-changing endpoints and forms, or enforce a strict `SameSite` policy plus `origin/Referer` verification on sensitive requests. Apply this uniformly across both the server-rendered forms and the JSON API.

I1: Email Spoofing Enabled by Missing DMARC/DKIM and Softfail SPF

Score	0.0 (Info)
Vector string	N/A
Target	thedownundernews.online (email domain)
References	• CWE-290 (Authentication Bypass by Spoofing) • OWASP Email Security

Overview

Severity: Low

The domain's email authentication is weak: there is no DMARC policy, no DKIM selectors, and the SPF record uses a soft-fail (`~all`) qualifier, allowing attackers to spoof `@thedownundernews.online` emails.

Details

DNS enumeration showed TXT `"v=spf1 include:spf.efwd.spaceship.net ~all"` with no `_dmarc.thedownundernews.online` record and no DKIM keys. Because the SPF qualifier is `~all` (softfail) rather than `-all` (hardfail), and no DMARC policy exists, receiving servers are not told to reject forged messages. This increases the risk of phishing emails that appear to originate from the news organization.

Recommendation

Change SPF to `-all`, publish a DMARC record (start with `p=none` for monitoring, then move to `p=quarantine/p=reject`), and configure DKIM signing on the outgoing mail provider.

I2: Gunicorn Application Port Directly Exposed to the Internet

Score	0.0 (Info)
Vector string	N/A
Target	51.161.130.70:5000 (thedownundernews.online)
References	• CWE-16 (Configuration) • OWASP Transport/Network Hardening

Overview

Severity: Informational

The Gunicorn WSGI server is directly reachable on port 5000, bypassing the nginx reverse proxy that otherwise fronts the application.

Details

Port 5000 on the main web VPS serves the same application content directly (Server: gunicorn), meaning any nginx-level protections (rate limiting, security headers, logging, WAF rules) are not applied to traffic that hits port 5000. This expands the attack surface without adding a compensating control.

Recommendation

Bind Gunicorn to the loopback interface (127.0.0.1:5000) so it is only reachable through nginx, and block port 5000 at the firewall/security-group level.

I3: Malformed Editor Account Email Address	
Score	0.0 (Info)
Vector string	N/A
Target	thedownundernews.online (user database)
References	CWE-20 (Improper Input Validation)

Overview

Severity: Informational

The editor test account's stored email address is malformed, containing the substring "Administrator" embedded mid-domain.

Details

The user list shows the editor account email as `editor@thedoAdministratorwnundernews.it.com` (anomalous "Administrator" inserted inside the domain). This appears to be a data-entry/validation defect rather than a security vulnerability, but it can break email delivery and indicates the account-provisioning workflow lacks email validation.

Recommendation

Correct the email address and add server-side email format validation to the user create/edit flow.

I4: Media Subdomain Backend Returns 502 Bad Gateway

Score	0.0 (Info)
Vector string	N/A
Target	https://media.thedownundernews.online/ (51.161.131.195)
References	Availability / operational finding

Overview

Severity: Informational

The media subdomain's web backend is currently down, returning an nginx 502 Bad Gateway, while its FTP and SSH services remain internet-exposed.

Details

`https://media.thedownundernews.online/` returns 502 Bad Gateway, indicating the upstream media application is not running or is misconfigured. HTTP (port 80) redirects to HTTPS, but the HTTPS backend is unreachable. This is an availability/operations issue rather than a direct vulnerability, but it leaves a partially-configured public-facing host.

Recommendation

Bring the media backend up or remove the public vhost; restrict the media host's FTP/SSH services to administrative networks, and ensure TLS is correctly configured once the service is restored.

I5: Missing HTTP Security Headers (HSTS, CSP, X-Frame-Options, X-Content-Type-Options)

Score	0.0 (Info)
Vector string	N/A
Target	• https://thedownundernews.online/ • https://www.thedownundernews.online/ • http://51.161.130.70:5000/
References	• OWASP Secure Headers Project • CWE-693 • CWE-1021 (Clickjacking)

Overview

Severity: Medium

The web application does not return any of the standard security hardening headers, leaving the site and its admin panel exposed to clickjacking, MIME-sniffing, and HTTPS downgrade (SSL stripping) attacks.

Details

A HEAD request to the site returned only `Server`, `Date`, `Content-Type`, `Content-Length`, and `Connection`. The following are all absent: `Strict-Transport-Security` (HSTS), `Content-Security-Policy` (CSP), `X-Frame-Options`, `X-Content-Type-Options`, `Referrer-Policy`, and `Permissions-Policy`.

The absence of HSTS is especially significant because the session cookie is also missing the `Secure` flag, meaning a network attacker could strip HTTPS and capture the admin session. The absence of `X-Frame-Options` /CSP frame-ancestors allows the admin panel to be framed (clickjacking).

Recommendation

Enable HSTS with `max-age` and `includeSubDomains` at the nginx or application layer, set a strict `Content-Security-Policy`, add `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY` (or `CSP frame-ancestors 'none'`), and a sane `Referrer-Policy`. Apply these consistently via the nginx reverse proxy so they cover both the apex and the directly-exposed Unicorn port.

I6: TLS Certificate SAN Mismatch on www Subdomain

Score	0.0 (Info)
Vector string	N/A
Target	https://www.thedownundernews.online/
References	CWE-295 (Improper Certificate Validation)

Overview

Severity: Low

The TLS certificate presented for `www.thedownundernews.online` only covers the apex domain `thedownundernews.online`, causing browser certificate warnings for visitors to the www hostname.

Details

The Let's Encrypt certificate has `CN=thedownundernews.online` and a SAN list that does not include `www.thedownundernews.online`. Visiting `https://www.thedownundernews.online/` therefore triggers a hostname-mismatch certificate error (curl exit 60). Both hostnames serve identical content.

Recommendation

Re-issue the certificate to include both `thedownundernews.online` and `www.thedownundernews.online` (and any other public hostnames), or redirect www to the apex consistently.

I7: Unauthenticated API Discloses Author PII and Internal Identifiers

Score	0.0 (Info)
Vector string	N/A
Target	https://thedownundernews.online/api/articles
References	• OWASP API Security Top 10 (API1:2023 BOLA / API3:2023 Excessive Data Exposure) • CWE-200

Overview

Severity: Low

The public, unauthenticated `/api/articles` endpoint returns more data than the front end needs, including author email addresses, usernames, roles, internal IDs, and account metadata.

Details

`GET /api/articles` returns a JSON payload where each article embeds its full author object (`id`, `username`, `first_name`, `last_name`, `email`, `role`, `is_active`, `created_at`) and category object (including `id`, `display_order`, `article_count`). The admin account email and the accounts' internal user IDs and roles are exposed to any anonymous visitor. This aids targeted phishing and account reconnaissance. (The `/api/admin/*` endpoints were verified to require authentication and role checks.)

Recommendation

Return only the fields the public front end requires (e.g. author display name) and strip email, role, `is_active`, and internal IDs from public responses. Apply a data-minimization layer to the public API.

5 Disclaimer

The purpose of this research project is to help evaluating the seamlessness, effectiveness and cost-benefit ratio of autonomously performing vulnerability assessment using agentic AI. I do not take any responsibility upon any misuse or abuse of such tool where it can face significant legal actions.

A Appendix

A.1 Static Appendix Section

A.2 Limitations & Constraints

The following limitations applied to this engagement:

- Stored cross-site scripting via the article body was not tested, as this would have required creating content on the production system.
- The JWT signing secret was not brute-forced beyond a bounded list of common secrets (per engagement rules).
- No destructive, denial-of-service, or lateral-movement testing was performed.
- A phone number for the business was not available at the time of reporting.

All testing was performed within the approved scope and without destructive impact.

A.3 Severity Classification

Findings are rated on the following scale:

Severity	Meaning
Critical	Immediate action required; can lead to full system compromise.
High	Serious issue that can compromise significant functionality or data.
Medium	Notable weakness requiring prompt remediation.
Low	Minor weakness that reduces defense-in-depth.
Informational	No direct exploitability; noted for awareness and hardening.

Where an explicit CVSS v3.1 vector was provided in the source findings, it is recorded on the finding. Findings without a CVSS vector are shown as "N/A" in the CVSS-driven scoring, while their assessed severity is stated in each finding and in the executive summary.